



AboutCode Foundation

PURL actually

with Philippe Ombredanne, AboutCode

**FOSS-first mission: Make it easier to reuse open source,
safely and efficiently, with open source code and open data**

Philippe Ombredanne



pombredanne@aboutcode.org

<https://github.com/pombredanne>

<https://www.linkedin.com/in/philippeombredanne>

- Lead maintainer of AboutCode and ScanCode
 - Open source code, data, and standards to automate and secure software supply chains with transparency and confidence
 - <https://aboutcode.org>
- Creator of PURL (Package-URL, ECMA-427) and VERS, co-founder of SPDX and ClearlyDefined, and core contributor to CycloneDX (ECMA-424)
- CTO and co-founder of nexB
 - Providing SCA services and AboutCode support since 2007
 - <https://nexb.com>

PURL actually

Agenda

Vulnerability management today: Compliance vs security

Stop doing vulnerability databases: The vulnerability-centric approach isn't working

PURL to the rescue: First, what is PURL? Then, the package-centric approach

Planned roadmap: Current status and roadmap for PURL

Calls to action: Join and participate

**There are competing interests
between compliance and
improved security.**

Vulnerability management today

Less is more for compliance

- CRA (EU), FedRAMP (US), and other regulations introduce more constraints on business and software development for more secure software
- For compliance, the goal is to reduce or eradicate the burden as much as possible
- Security does not matter for compliance

A man with short dark hair, wearing a dark shirt, is holding a large white sign. The sign has bold black text that reads: 'MORE COSTS, LESS FREEDOM' followed by 'Cure: Pain Killer!' on the next line. The background behind the man is dark with some out-of-focus lights.

**MORE COSTS,
LESS FREEDOM
Cure: Pain Killer!**

Vulnerability management today

More is more for security

- For security, I want the best security money can buy for my organization and software product and team
- And the most efficient approach that does not slow down business and development

A man with short dark hair, wearing a dark shirt, is holding a large white sign. The background is dark with some bokeh lights.

**LESS COSTS,
MORE FREEDOM
Cure: Vitamins!**

**The vulnerability-centric approach
for vulnerability management
isn't working.**

The vulnerability-centric approach worked in the 1990s

- Identifying which software you used was not the problem
 - Every piece of software was distributed by a vendor
 - Microsoft for Word
 - Adobe for Acrobat
 - And only a few software vendors
 - Most software was running on Windows (98 ;))



And since the 2000s, the rise of the packages

- We finally can assemble software from components, like with LEGO®
- Now, identifying which software you use is the problem
 - There are millions
 - And from all over the places
 - Forked, patched, remixed
- The bulk of software component creators are open source developers
 - And most software projects and products are built using mostly open source components
- Most software is running on Linux and POSIX OSes
- We use JavaScript and npm by the 1,000s
- ... and further mix these with 10,000 packages in containers

Stop doing vulnerability databases.



We need package databases, that include security bugs.

- Software practitioners (today) don't care for vulnerabilities
- Instead, they want practical and actionable bugs in the packages they use in their systems, products and applications
- With a patch or upgrade path
- Different packagings from the same upstream MAY NOT HAVE THE SAME VULNERABILITIES

A man with light brown hair, wearing a dark suit and white shirt, is speaking into a microphone. He has a serious expression. In the background, a woman in a red dress is visible, slightly out of focus. The scene appears to be a formal event or press conference.

**PURL to the rescue for our
package-centric world!**

PURL is the standard for package identification across ecosystems

- Package-URL (PURL) is the glue between all your software supply chain tools, data, and standards
 - o Adopted in all SBOM and VEX specs
 - o Most SCA tools
 - o Many vulnerability databases
- Across Dev to Ops to Sec (to DevSecOps)
- Simple, obvious, expressive syntax:
 - o `pkg:npm/file@1.9.1`
 - o `pkg:deb/ubuntu/7zip@21.07+dfsg-4`
 - o `pkg:pypi/django@1.11.1`
- Ecma standard at TC54
 - o Planned ISO JTC1 standardization
 - o Already included in CycloneDX, OASIS, ISO CSAF, and CVE schema

What is PURL?

PURL actually

PURL enables interoperability between tools, data, and standards

- Consistent identification across formats
 - o Reference the same package using identical PURL identifiers



`contributing.yaml`

What is PURL?

PURL actually

PURL is adopted industry- and community-wide

All open source SCA and SBOM tools use PURL, including:

- Linux Foundation's OSS Review Toolkit, and Fossology
- OpenSSF OSV and GUAC
- OWASP Dependency-Track, Dependency-Check, and cdxgen
- All OWASP CycloneDX libraries
- GitHub's Dependency Graph
- Microsoft's OSS Gadget, SBOM tool
- Anchore's Syft and Grype
- Aquasec's Trivy
- LG's FOSSLight
- SCANOSS
- Snyk's Parlay

Most proprietary SCA, SBOM, and code host tools use PURL, including:

- GitHub
- GitLab
- Snyk
- Mend
- BlackDuck
- Sonatype

Vulnerability databases use PURL, including:

- Google's OSV
- Sonatype's OSS Index
- CVE specification v5.1
- VulnerableCode

PURL facilitates better compliance processes for end users, including:

- Most free and open source software foundations
- Five of the Big Tech companies, with three building their entire SCA compliance operations on PURL
- A leading database company
- A leading Linux company
- European and US government agencies
- All major European car manufacturers and most of their vendors
- Major US chip and microprocessor providers
- Four leading European industrial companies
- A leading European medical devices company

And VERS is a new standard for version ranges syntax

- Problem: Each ecosystem has its own convention to specify version ranges
- Solution: An expressive version range string that is minimal and PURL adjunct
 - Specify ranges reliably across tools and languages for dependencies and vulnerabilities
 - Path to universal dependency resolution and better vulnerability remediation automation
- A version range specifier (VERS) is a URI with this syntax:
 - **vers:npm/1.2.3|>=2.0.0|<5.0.0**
 - **vers:pypi/0.0.1|0.0.2|2.0pre1**
- Started with VulnerableCode in the "univers" library and now used in CycloneDX, CLE, TEA, CSAF and ScanCode
- Planned Ecma standardization with TC54-TG2

What is PURL?

PURL actually

Disclose better vulnerabilities

- Standardized VEX format interoperability
 - o Precise vulnerability matching and license compliance checking with accurate package identification



<https://docs.oasis-open.org/csaf/csaf/v2.0/os/csaf-v2.0-os.html#31334-full-product-name-type---product-identification-helper---purl>



https://cyclonedx.org/docs/1.6/json/#components_items_purl



<https://docs.oasis-open.org/csaf/csaf/v2.0/os/csaf-v2.0-os.html#31334-full-product-name-type---product-identification-helper---purl>

The package-centric approach

- Zero friction from scan to vulnerability determination to actionable remediation
- With CPEs, scan results are not actionable
 - o Requires searching a vulnerability database to find a software package
 - o And CPEs exist only for vulnerable packages, while PURLs always exist

Actionable data, keyed by PURL



ClearlyDefined supports converting PURLs to "Coordinates" format in its data model.
<https://docs.clearlydefined.io/docs/resources/coordinates#purl-type-mapping>

Sonatype OSS Index

OSS Index can consistently map components to their corresponding vulnerability data using PURL.
<https://ossindex.sonatype.org/doc/coordinates>

AboutCode PurlDB

Continuously updated reference data for open source packages' origin, information and licensing, utilizing PURL.
<https://github.com/aboutcode-org/purldb>

ecosyste.ms

Lookup information about a PURL in both text and JSON formats.
<https://github.com/andrew/purl>

deps.dev

PURLs serve as unique identifiers for allows for precise tracking and analysis of dependencies within the deps.dev system.
<https://docs.deps.dev/api/v3alpha/#purllookup>

OSV

OSV uses PURLs to identify packages within its database and API queries.
<https://ossf.github.io/osv-schema/#affectedpackage-field>

Beside PURLs, what else?

- CPE
- Checksums, hashes
- OmniBOR: Checksum-based
- SWHID: Checksum-based
- PURL look-alike with an ecosystem, name and version (in latest CVE and also in OSV)
- Plain URLs for download
- All of these can be useful
- Checksums actually help point to precise files
 - Like a GPS vs. street address
 - Not human readable

More standardization for better PURLs

- Make PURL as ISO standard
- Make VERS an ECMA standard
- Structured PURL types as JSON
- Work with PURL library maintainers to adopt test suites and upgrade to the latest standard
- Validate all the PURLS!
 - Open source tools to validate PURL syntax and validation service API
 - Open data (and tool) to validate existence (offline)
 - Extensive test suite as data (JSON)

Expand support for package ecosystems

- "Beach" cleaning" packages for Rust, Maven, and Nix
- C/C++ PURL registry
- Open data keyed by PURL
 - PurlDB + vulnerability DB
 - AboutCode + ClearlyDefined
 - AboutCode + Software Heritage
 - Scan billions of files, get billions of PURLs

Planned roadmap

Create a PURL benchmark

- Thoroughly validated set of open source app, container and package codebases
- Goal = scanning tools can check they return the exact list of correct PURLs found in a codebase
 - o Peer reviewed and updated!
 - o Precursor to a future open SBOM benchmark



Together, we can build better software compliance processes

PURL actually

Community support to help us do good!

- German Sovereign Tech Agency (STF) to support PURL and standardization
- Grants from NLnet Foundation with the EU NGI programs all about PURL:
 - o CRAVEX, FederatedCode, T-Rust, back2source, Maven Heaven
- Grants from EU NGI Search:
 - o AI-Generated Code Search, matching PURLs
- Completed GitHub Secure OSS Fund
- EU and ECCC (European Cybersecurity Competence Centre)-funded OCCTET project: occtet.eu
 - o with Eclipse, DoubleOpen, Bitsea, European Digital SME Alliance, Expertware, Red Alert Labs
- ZEISS FOSS Award, Bloomberg FOSS Grant, Mercedes FOSS grant, Microsoft grant
- And grants from from two US big tech, two large US and several EU companies
- **Help us do more!**

Make good
vulnerability databases
with ...

PURL actually! *

*I agree



Together, we can build better software compliance processes

PURL actually

Join the community and contribute!

AboutCode

GitHub: github.com/aboutcode-org

Slack: join.slack.com/t/aboutcode-org/shared_invite/zt-1paqwxccw-luafuiAvYJfKtQGaZsC1og

Community calls:
Mondays at 15:00 UTC at
meet.jit.si/AboutCode

 **PURL + VERS**

github.com/package-url/purl-spec

Join #purl channel on AboutCode slack
for latest updates

Community calls:
Biweekly on Wednesdays at 16:00 UTC at
meet.google.com/ryq-aimn-ghd

Help with the 200+ issues:
github.com/orgs/aboutcode-org/projects/52/views/39 and
github.com/package-url/purl-spec/issues

 ClearlyDefined

docs.clearlydefined.io/docs/get-involved/

 CycloneDX

cyclonedx.org/participate/contribute/

 **SPDX®**

spdx.dev/engage/participate/

Let's connect!

PURL actually

Any questions?



pombredanne@aboutcode.org

<https://github.com/pombredanne>

<https://www.linkedin.com/in/philippeombredanne>

**PURL is all around us
And so the security grows
It identifies packages
It's everywhere you code
So if you want compliance
Use PURL for your workflows**

Lyrics adapted from The Troggs. "Love is All Around." *Cellophane*, Page One / Fontana, 1967.

Images from *Love Actually*. Directed by Richard Curtis, Universal Pictures, 2003.